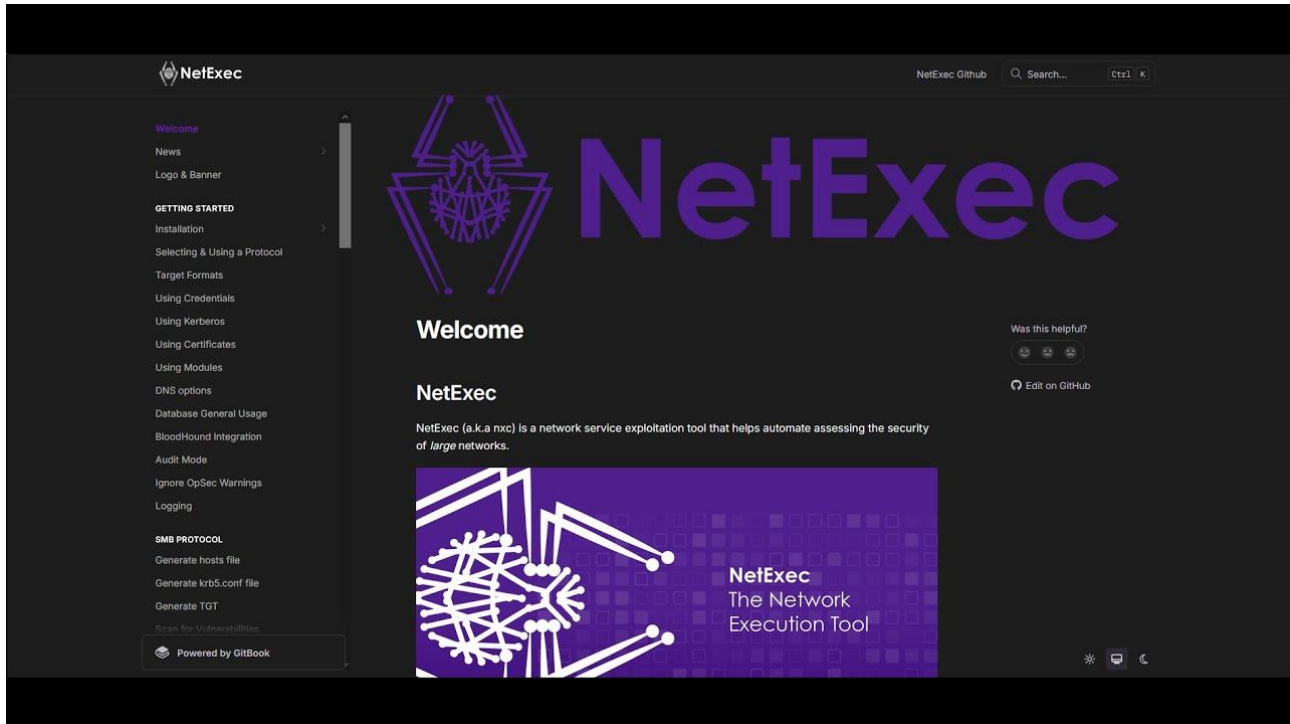


TOOLSET FOR ACTIVE DIRECTORY PENTESTING (PART I)

- By Alham Rizvi

1. NetExec



1.1 What is NetExec

NetExec (formerly CrackMapExec) is a post-exploitation and enumeration framework for Active Directory environments.

It combines:

1. Authentication testing
2. Enumeration
3. Remote command execution
4. Credential dumping
5. Module-based attacks

Repository:

<https://github.com/Pennyw0rth/NetExec>

1.2 How NetExec Works

1. You provide target IPs or ranges
2. You provide credentials (password, NTLM hash, Kerberos ticket)
3. NetExec attempts authentication over multiple protocols
4. If successful, it performs enumeration or exploitation

Supported protocols:

1. SMB
2. LDAP

3. WinRM

4. MSSQL

1.3 Common NetExec Commands (Lab Use)

Test SMB authentication:

```
netexec smb 192.168.1.0/24 -u user -p password
```

Enumerate shares:

```
netexec smb 192.168.1.10 -u user -p password --shares
```

Enumerate active sessions:

```
netexec smb 192.168.1.10 -u user -p password --sessions
```

Check local administrator access:

```
netexec smb 192.168.1.0/24 -u user -p password --local-admins
```

Dump credentials (requires privileges):

```
netexec smb 192.168.1.10 -u admin -p password --lsa
```

8. Summary Table

Command	Purpose
smb auth test	Find where credentials work
--shares	Discover sensitive files
--sessions	Identify logged-in privileged users
--local-admins	Find admin access
--lsa	Extract credentials

Tool 2: BloodHound AD



2. 1. What is BloodHound

BloodHound is an **Active Directory relationship analysis tool** used for **offensive security**.

Its main purpose is to answer one critical question:

How can an attacker move from a low-privileged user to high privileges such as Domain Admin?

BloodHound does **not exploit systems directly**.

Instead, it **maps relationships and permissions** that already exist in Active Directory.

2. 2. Core Idea Behind BloodHound

Active Directory is not flat. It is a **graph of relationships**.

Examples:

1. User is a member of a group
2. Group has admin rights on a computer
3. Computer has a logged-in domain admin
4. User can reset another user's password
5. User can modify group membership

BloodHound models all of this as a **graph**.

2. 3. BloodHound Architecture

BloodHound has **two main components**:

3.1 SharpHound (Collector)

Purpose:

1. Collects data from Active Directory
2. Runs on Windows or Linux
3. Outputs data files

2.4 BloodHound GUI

Purpose:

1. Imports collected data
2. Stores it in a Neo4j graph database
3. Allows querying and visualization

2. 5 What Data BloodHound Collects

SharpHound can collect:

1. Users
2. Groups
3. Computers
4. Sessions (who is logged in where)
5. Group memberships
6. Access Control Lists (ACLs)
7. Domain trusts
8. Delegation settings

This data is what allows BloodHound to calculate attack paths.

2.6 SharpHound Collection Commands

2.6.1 Windows Collection (Most Common)

SharpHound.exe -c All

What this means:

1. -c stands for collection methods
2. All enables all available collection techniques

Output:

1. ZIP file
2. Contains JSON files
3. Ready for import into BloodHound

2.6.2 Windows Stealth Collection (Example)

SharpHound.exe -c Session,LocalAdmin

What this does:

1. Collects logged-on users
2. Collects local admin relationships
3. Less noisy than full collection

2.6.3 Linux Collection Using NetExec

netexec ldap 192.168.1.10 -u user -p password --bloodhound

What this does:

1. Authenticates to LDAP
2. Queries Active Directory objects
3. Outputs BloodHound-compatible data

2.7 Importing Data into BloodHound

Steps:

1. Start Neo4j database
2. Launch BloodHound GUI
3. Drag and drop SharpHound ZIP file
4. BloodHound parses data into a graph

Once imported, you can start analysis.

2.8 Understanding BloodHound Graphs

2.8.1 Nodes (Objects)

Nodes represent:

1. Users
2. Groups
3. Computers
4. Domains

2.8.2 Edges (Relationships)

Edges represent permissions or access.

Common edges:

1. MemberOf
2. AdminTo
3. CanRDP
4. HasSession
5. ForceChangePassword
6. WriteDACL
7. GenericAll
8. GenericWrite

10. Output of BloodHound

BloodHound provides:

1. Graph-based visualization
2. Clear attack paths
3. Query-based results
4. Exportable findings

It turns thousands of AD objects into **understandable privilege paths**.

11. Limitations of BloodHound

1. No exploitation
2. No credential dumping
3. No password attacks
4. Accuracy depends on data collection

5. Can miss short-lived sessions

BloodHound shows **what is possible**, not **what is guaranteed**.

12. How BloodHound Fits Into a Pentest

Typical workflow:

1. Gain initial credentials
2. Run SharpHound
3. Import data into BloodHound
4. Identify privilege escalation paths
5. Choose the safest and shortest path
6. Use other tools to execute the attack

BloodHound is the **planning and decision tool**.

Tool 3: PingCastle



PingCastle is an Active Directory security auditing and risk assessment tool.

Its objective is to evaluate the overall security posture of an Active Directory environment and identify major misconfigurations.

3.2 How PingCastle Works

3.2.1 Authentication Method

PingCastle authenticates to Active Directory using standard LDAP queries.

3.2.2 Data Collection

It collects configuration data only and does not perform exploitation.

3.2.3 Permission Requirements

Domain User privileges are sufficient for most checks.

3.3 Security Areas Analyzed by PingCastle

3.3.1 Authentication and Password Policies

1. Password length
2. Password complexity
3. Password expiration

3.3.2 Legacy and Insecure Protocols

1. NTLMv1 usage
2. SMBv1 usage
3. Old domain functional levels

3.3.3 Privilege Management

1. Excessive Domain Admins
2. Unrestricted delegation
3. Weak administrative separation

3.3.4 Trust Relationships

1. External trusts
2. Forest trusts
3. Transitive trust abuse potential

3.4 PingCastle Execution

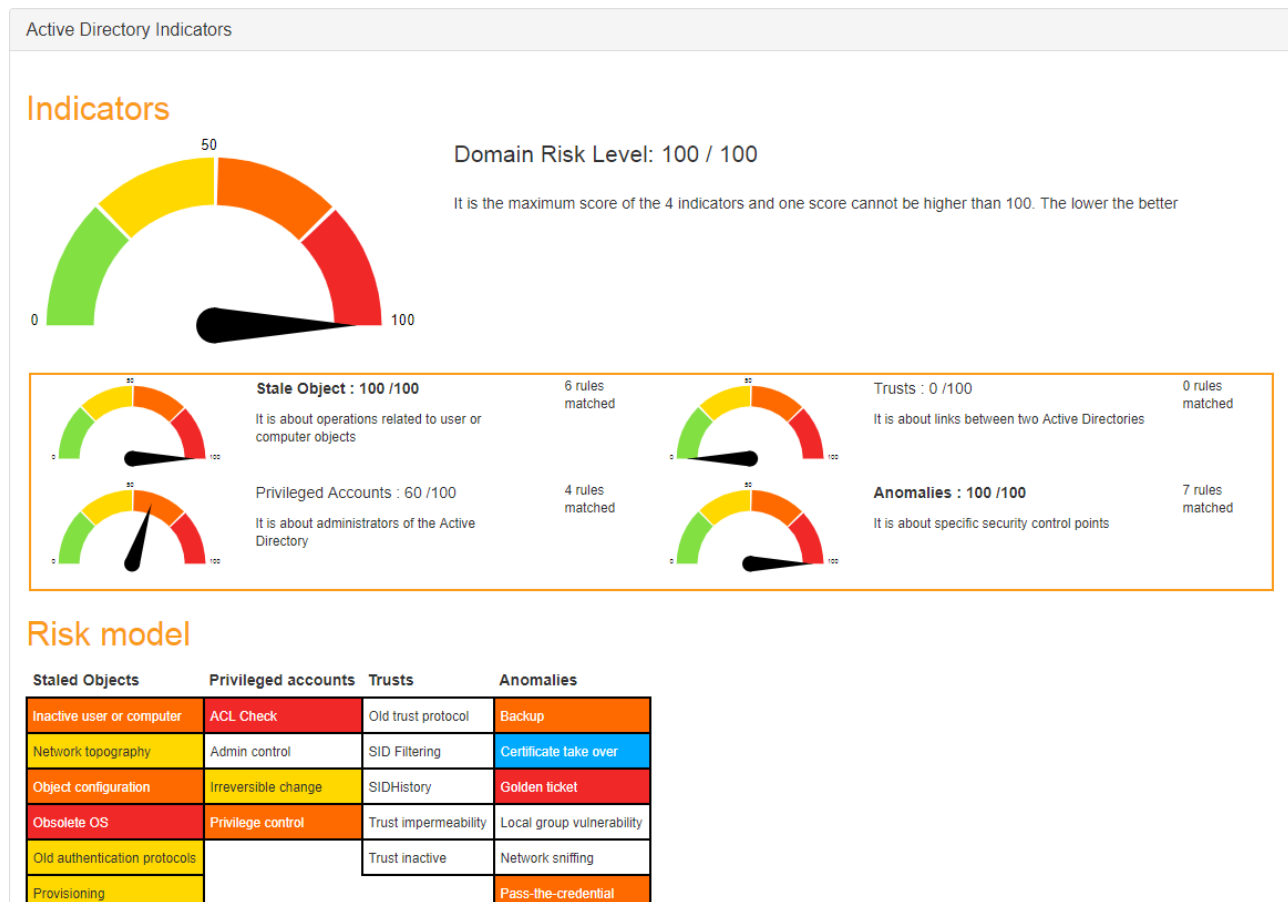
Basic Health Check

```
PingCastle.exe --healthcheck
```

Domain-Specific Health Check

```
PingCastle.exe --healthcheck --domain domain.local
```

3.5 PingCastle Output



3.5.1 Risk Score

A numerical score between 0 and 100 indicating overall risk.

3.5.2 Report Format

1. HTML report
2. Categorized findings (Critical, High, Medium, Low)

3.5.3 Report Content

Each finding includes:

1. Description
2. Security impact
3. Attack relevance
4. Remediation guidance

3.6 Limitations of PingCastle

No Exploitation Capability

PingCastle does not perform attacks.

Read-Only Nature

It cannot verify exploitability in practice.

Dependency on Directory Access

Requires network connectivity to the domain.

Tool 4: Impacket

4.1



Overview

- . Impacket is a Python-based toolkit for Active Directory and Windows network attacks
- . It implements Windows protocols directly in Python
- . It is widely used in professional AD pentesting
- . It runs mainly on Linux attack systems

4.2 Purpose

- . Perform direct Active Directory exploitation
- . Abuse authentication mechanisms
- . Execute commands remotely
- . Extract credentials
- . Enable lateral movement

4.3 Technical Foundation

- . Implements SMB, RPC, Kerberos, and LDAP
- . Does not rely on Windows binaries
- . Communicates directly with domain controllers and hosts
- . Highly flexible and scriptable

4.4 Important Impacket Tools

4.4.1 GetNPUsers.py (AS-REP Roasting)

- . Used to identify users without Kerberos preauthentication
- . Requests AS-REP responses from the Domain Controller
- . Extracts crackable Kerberos hashes

Example:

```
GetNPUsers.py domain.local/ -usersfile users.txt -dc-ip 192.168.1.10
```

Output:

- . Kerberos AS-REP hashes
- . Usernames associated with the hashes

4.4.2 GetUserSPNs.py (Kerberoasting)

- . Used to identify service accounts
- . Requests Kerberos service tickets
- . Extracts service ticket hashes

Example:

```
GetUserSPNs.py domain.local/user:password -dc-ip 192.168.1.10
```

Output:

- . Service account ticket hashes
- . SPN information

4.4.3 secretsdump.py

- . Used to extract credentials from Windows systems
- . Accesses SAM, LSA, and NTDS databases
- . Requires high privileges

Example:

```
secretsdump.py domain.local/admin:password@192.168.1.10
```

Extracted data:

- . NTLM hashes
- . Cached credentials
- . Domain secrets (if Domain Admin)

4.4.4 psexec.py

- . Used for remote command execution
- . Creates a temporary service on the target
- . Executes commands as SYSTEM

Example:

```
psexec.py domain.local/admin:password@192.168.1.10
```

Requirements:

- . Local administrator access
- . SMB connectivity

4.4.5 wmiexec.py

- . Used for stealthier remote command execution
- . Does not create a service
- . Executes commands via WMI

Example:

```
wmiexec.py domain.local/admin:password@192.168.1.10
```

4.5 Output

- . Credential hashes
- . Kerberos tickets
- . Remote command shells
- . Authentication material for lateral movement

4.6 Limitations

- . Requires correct privileges
- . High detection risk
- . No visualization or planning features
- . Easy to misuse without understanding

4.7 Role in Active Directory Pentesting

- . Used during exploitation phase
- . Executes attack paths discovered by BloodHound
- . Complements NetExec for automation
- . One of the most powerful AD toolsets

Tool 5: Kerbrute



5.1 Overview

- . Kerbrute is a Kerberos-focused Active Directory enumeration tool
- . It is written in Go
- . It interacts directly with the Kerberos protocol
- . It does not require SMB, LDAP, or Windows APIs
- . It is very fast and lightweight

5.2 Purpose

- . Enumerate valid domain usernames
- . Perform password spraying in lab environments
- . Identify accounts vulnerable to Kerberos-based attacks
- . Validate credentials without logging into systems

5.3 Why Kerbrute Is Important

- . Kerberos responds differently to valid and invalid users
- . Kerbrute abuses this behavior safely and efficiently
- . No authentication is required for user enumeration
- . Very stealthy compared to SMB or LDAP enumeration

5.4 How Kerbrute Works

- . Sends Kerberos authentication requests to the Domain Controller
- . Observes Kerberos error messages
- . Distinguishes between:
 - . Valid users
 - . Invalid users
 - . Locked or disabled accounts
- . Does not create Windows logon events

5.5 Kerbrute Modes

5.5.1 User Enumeration Mode

- . Identifies valid Active Directory usernames
- . Does not require credentials
- . Uses Kerberos preauthentication responses

Example:

```
kerbrute userenum --dc 192.168.1.10 users.txt domain.local
```

Input:

- . Domain Controller IP
- . Username wordlist
- . Domain name

Output:

- . List of valid domain users

5.5.2 Password Spraying Mode (Lab Only)

- . Tests one password against many users
- . Reduces account lockout risk
- . Common in real-world misconfigurations

Example:

```
kerbrute passwordspray --dc 192.168.1.10 users.txt Password123 domain.local
```

Output:

- . Valid username and password combinations

5.5.3 Credential Validation Mode

- . Verifies known credentials
- . Confirms whether a username and password are correct

Example:

```
kerbrute login --dc 192.168.1.10 user Password123 domain.local
```

5.6 Kerbrute Output

- . Valid users
- . Valid credentials (if spraying succeeds)
- . Clear success and failure messages
- . Minimal noise

5.7 Advantages of Kerbrute

- . Very fast
- . Low network noise
- . Does not touch SMB or LDAP
- . Effective early-stage reconnaissance
- . Ideal before NetExec or BloodHound

5.8 Limitations of Kerbrute

- . Only works against Kerberos-enabled domains
- . No privilege escalation
- . No exploitation
- . No credential dumping
- . Can trigger alerts if misused

5.9 Role in Active Directory Pentesting

- . Used at the very beginning of a pentest
- . Helps build a valid user list
- . Feeds data into:
 - . NetExec
 - . BloodHound
 - . Impacket

Kerbrute is an **initial access and reconnaissance tool**, not an exploitation tool.

5.10 Typical Tool Chain Placement

1. Kerbrute – user enumeration
2. NetExec – authentication and enumeration
3. BloodHound – attack path discovery
4. Impacket – exploitation and lateral movement

Tools Covered (1–5) and Their Purpose

1. NetExec

What it is

- . An Active Directory enumeration and exploitation framework
- . Uses SMB, LDAP, WinRM, and MSSQL

What it does

- . Tests credentials across many hosts
- . Enumerates shares, sessions, and local admin access
- . Executes commands remotely
- . Dumps credentials when privileged
- . Automates common AD attacks

Main role

- . Fast reconnaissance and lateral movement

2. BloodHound AD

What it is

- . Active Directory relationship and privilege analysis tool
- . Uses a graph database (Neo4j)

What it does

- . Maps users, groups, computers, and permissions
- . Identifies privilege escalation paths
- . Visualizes attack chains to Domain Admin
- . Analyzes ACLs and trust relationships

Main role

- . Attack path discovery and planning

3. PingCastle

What it is

- . Active Directory security auditing tool
- . Configuration and risk assessment focused

What it does

- . Analyzes AD security posture
- . Detects misconfigurations and legacy weaknesses
- . Assigns a domain risk score
- . Generates detailed HTML reports

Main role

- . High-level security assessment and prioritization

4. Impacket

What it is

- . Python-based toolkit implementing Windows protocols

What it does

- . Performs Kerberos attacks (AS-REP, Kerberoasting)
- . Dumps credentials and secrets
- . Executes commands remotely
- . Enables lateral movement and privilege escalation

Main role

- . Direct exploitation and execution

5. Kerbrute

What it is

- . Kerberos-based Active Directory enumeration tool

What it does

- . Enumerates valid domain users
- . Performs password spraying (lab use)
- . Validates credentials
- . Uses Kerberos error responses

Main role

- . Early-stage reconnaissance and user discovery

One-Line Summary Table

Tool	Primary Purpose
NetExec	Enumeration and automation
BloodHound	Privilege escalation planning
PingCastle	AD security posture analysis
Impacket	Exploitation and lateral movement
Kerbrute	User enumeration via Kerberos

How They Fit Together in a Pentest

1. Kerbrute – find valid users
2. NetExec – test credentials and enumerate hosts
3. BloodHound – find attack paths
4. PingCastle – identify major weaknesses
5. Impacket – execute attacks